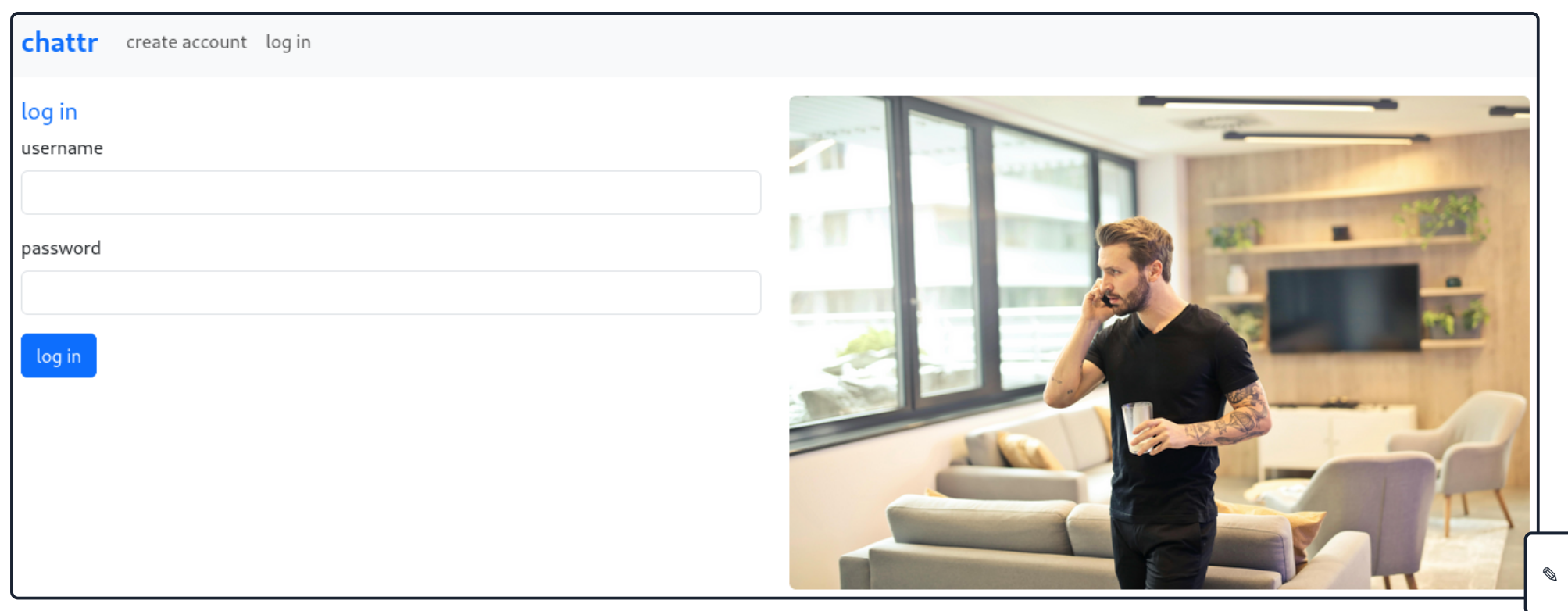


Skills Assessment - SQL Injection Fundamentals

Scenario

You have been contracted by **chattr GmbH** to conduct a penetration test of their web application. In light of a recent breach of one of their main competitors, they are particularly concerned with **SQL injection vulnerabilities** and the damage the discovery and successful exploitation of this attack could do to their public image and bottom line.

They provided a target IP address and no further information about their website. Perform an assessment specifically focused on testing for SQL injection vulnerabilities on the web application from a "black box" approach.

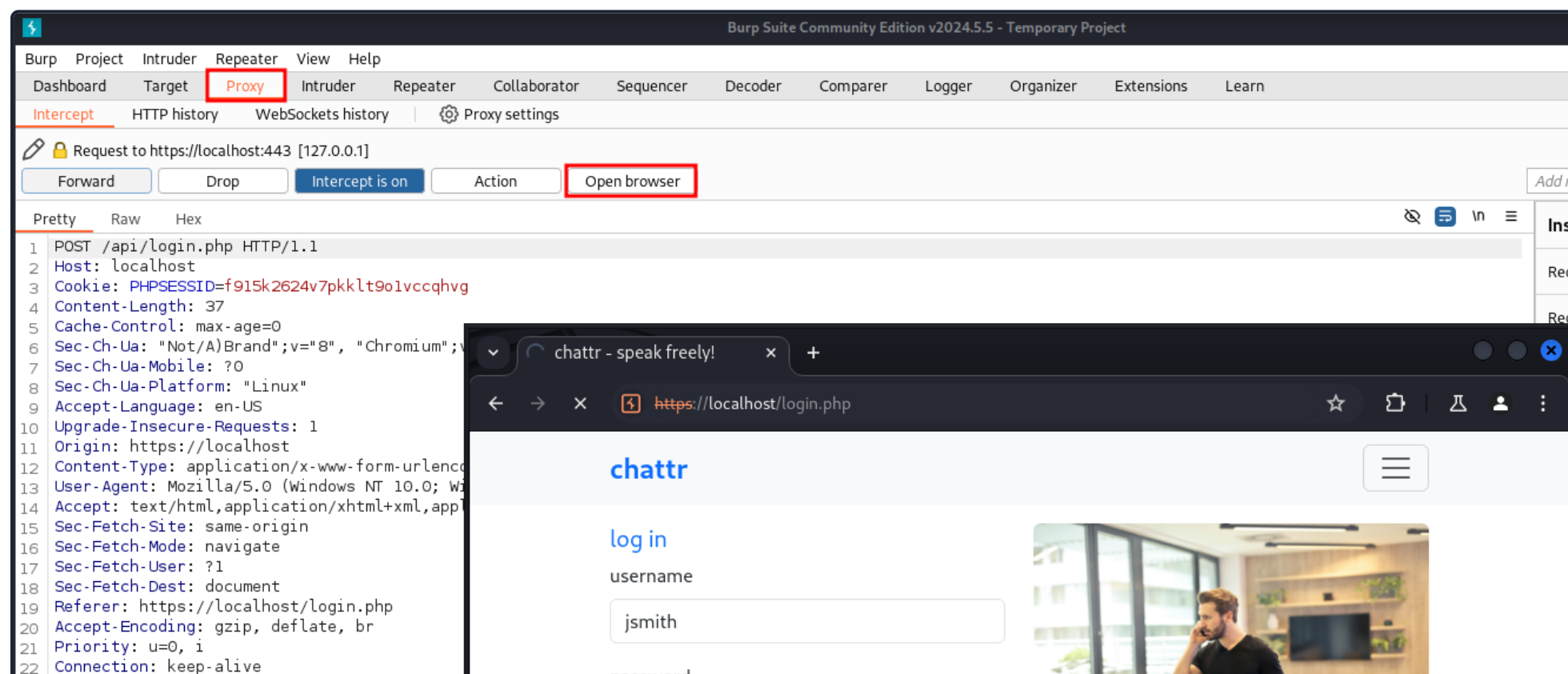


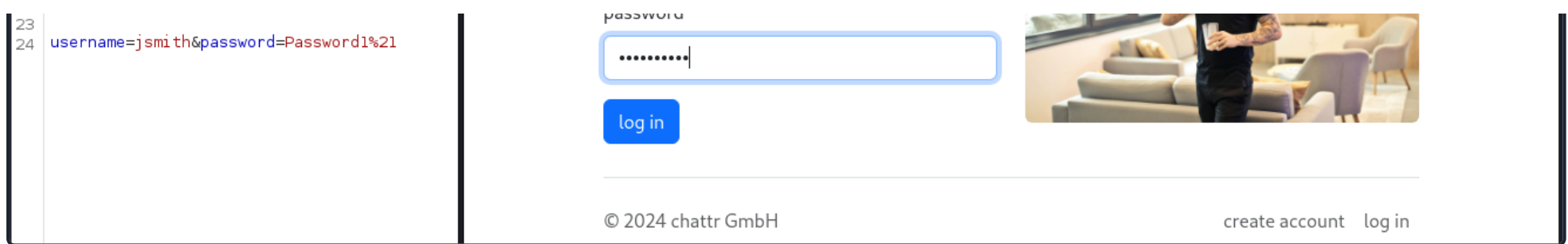
Intercepting HTTPS Traffic with Burp Suite

The web application in this skills assessment uses **HTTPS**, which **Burp Suite** can not be intercept by default. To do so, it is necessary to either install **Burp Suite's Certificate Authority (CA)** in your browser, or to use the **integrated browser in Burp Suite**.

Option 1: Using Burp Suite's Integrated Browser (Chromium)

One way to intercept traffic to websites that use HTTPS is to use the browser integrated into Burp Suite. To do so, simply navigate to the **Proxy** tab and click **Open browser**. In addition to intercepting HTTPS traffic, the integrated browser has a couple of Burp Suite's browser extensions pre-installed, such as **DOM Invader**, which is a useful tool for identifying DOM-based XSS.

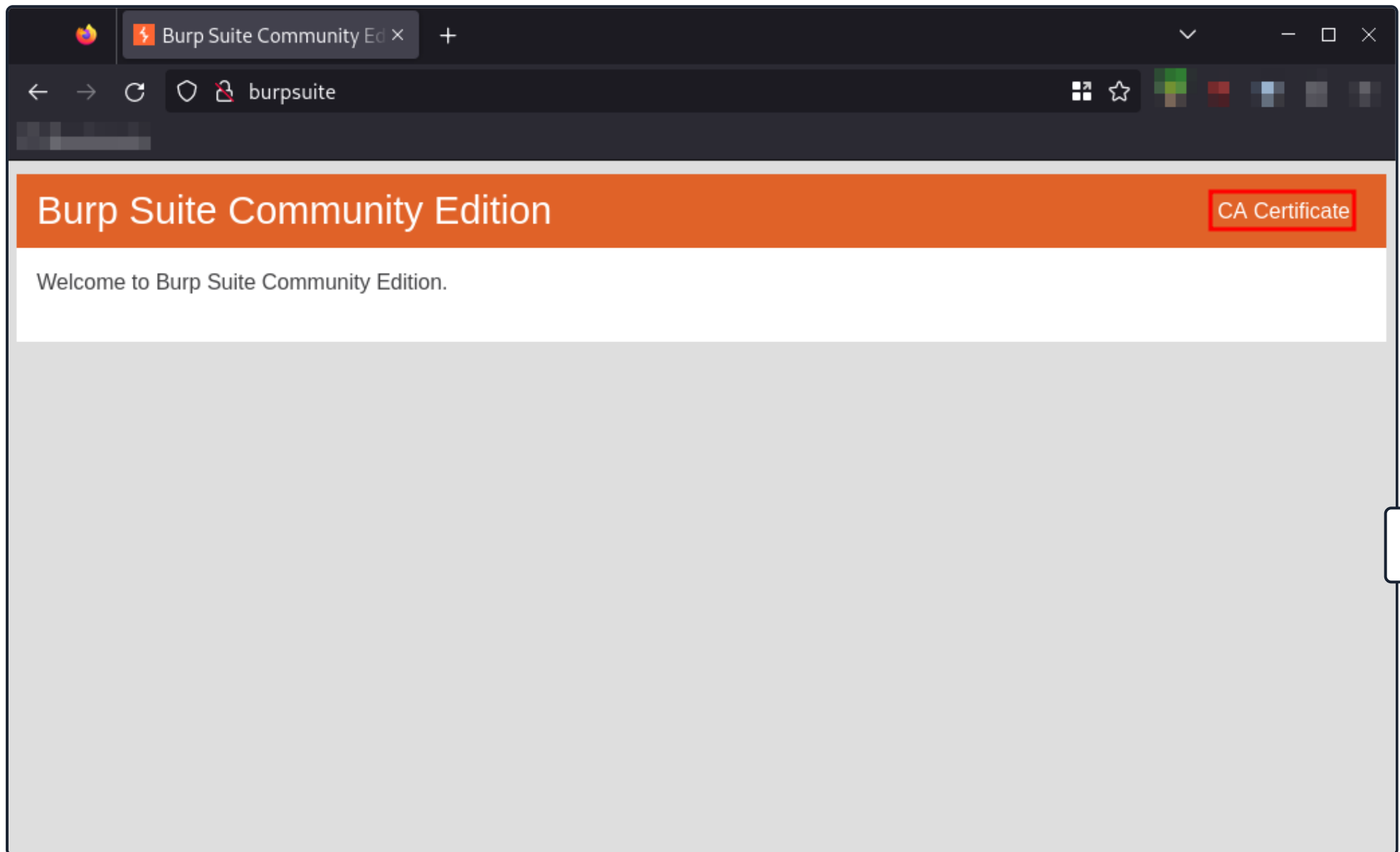




Option 2: Installing PortSwigger's CA in your own Browser

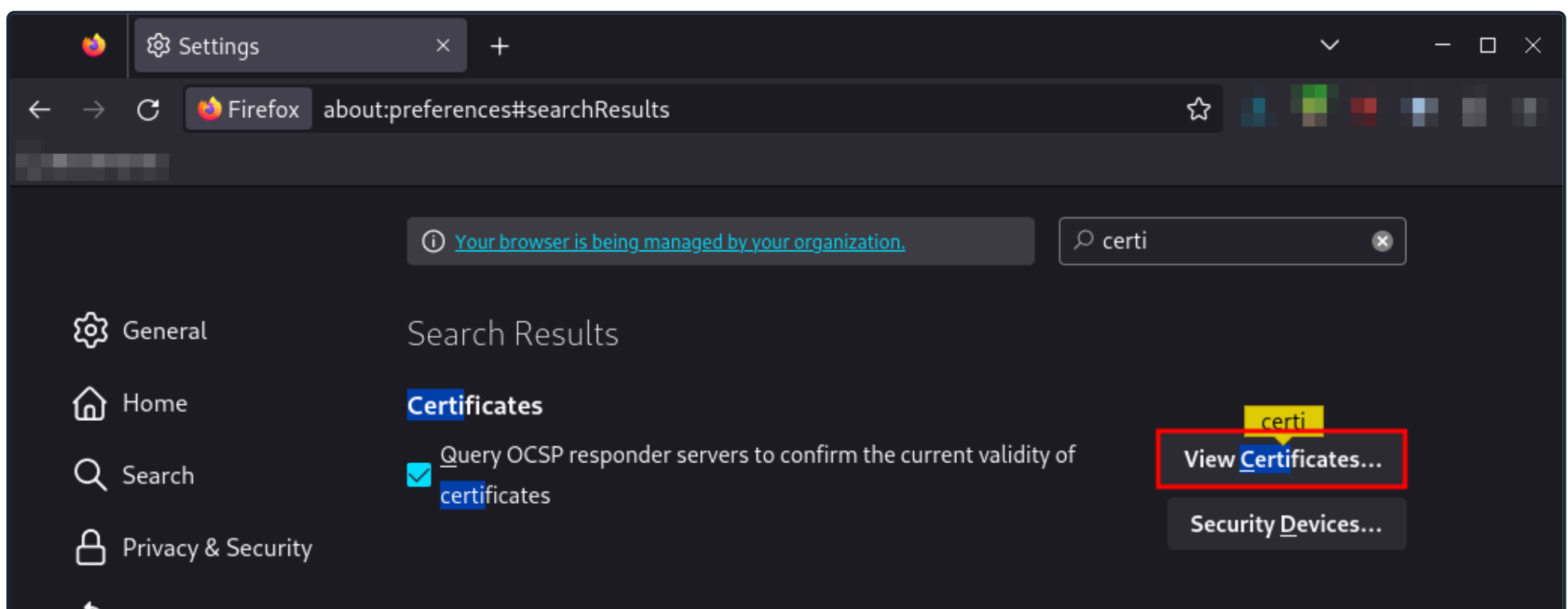
The other way to intercept traffic to websites that use HTTPS, is to install Burp Suite's CA into your web browser of choice. PortSwigger has an [article](#) which documents the process for [Chrome](#), [Firefox](#), and [Safari](#). For example, let's see how it works in [Firefox](#).

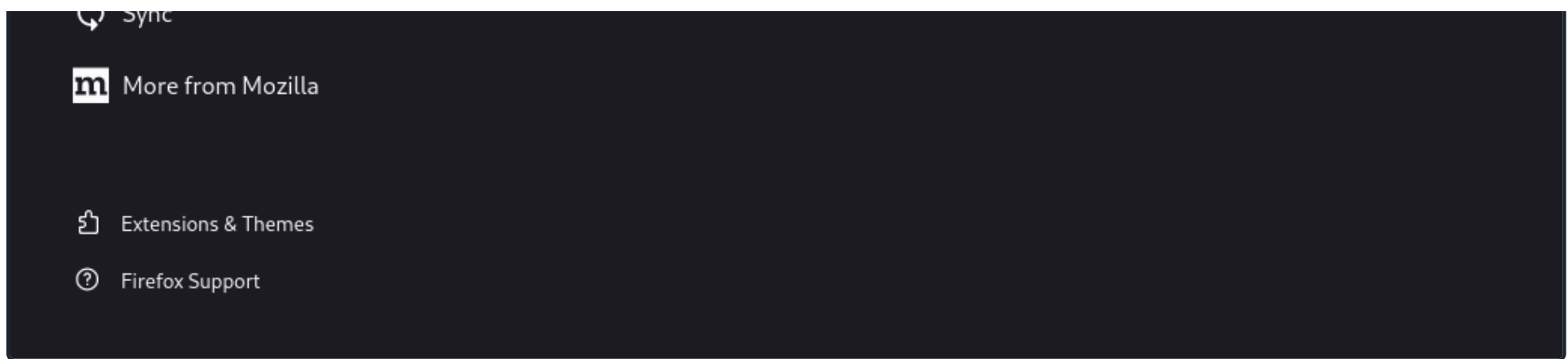
After configuring your browser to use Burp Suite as a proxy (default: <http://localhost:8080>), go to <http://burpsuite>. You should see the following page:



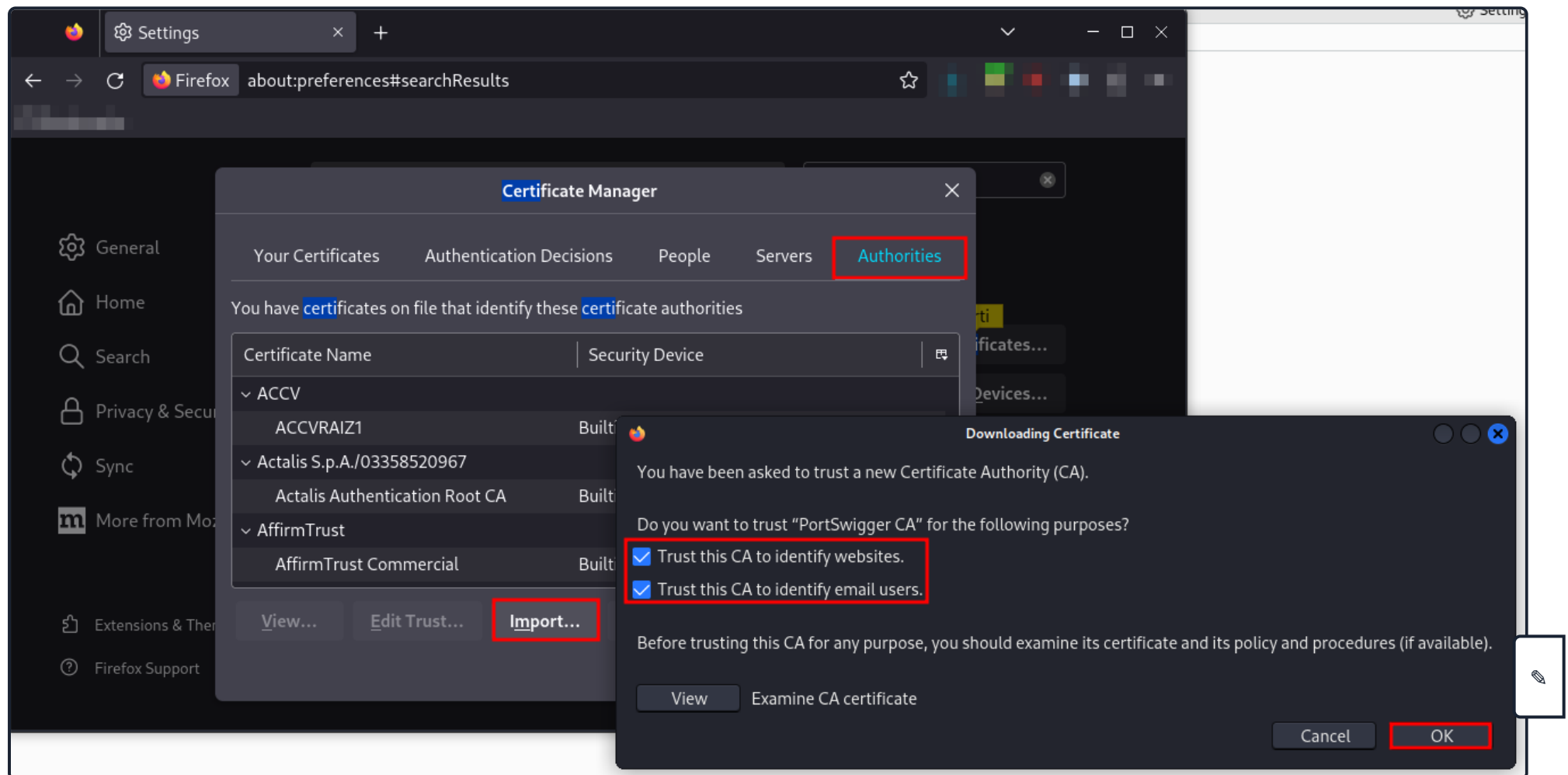
Click on [CA Certificate](#) and save [cacert.der](#) to a known location. This is [Burp Suite's CA](#) which will need to import into [Firefox](#), so that the browser will trust the proxy.

Next, head over to [Settings](#), and search for "[Certificates](#)". You will need to click on the [View Certificates...](#) button shown below:



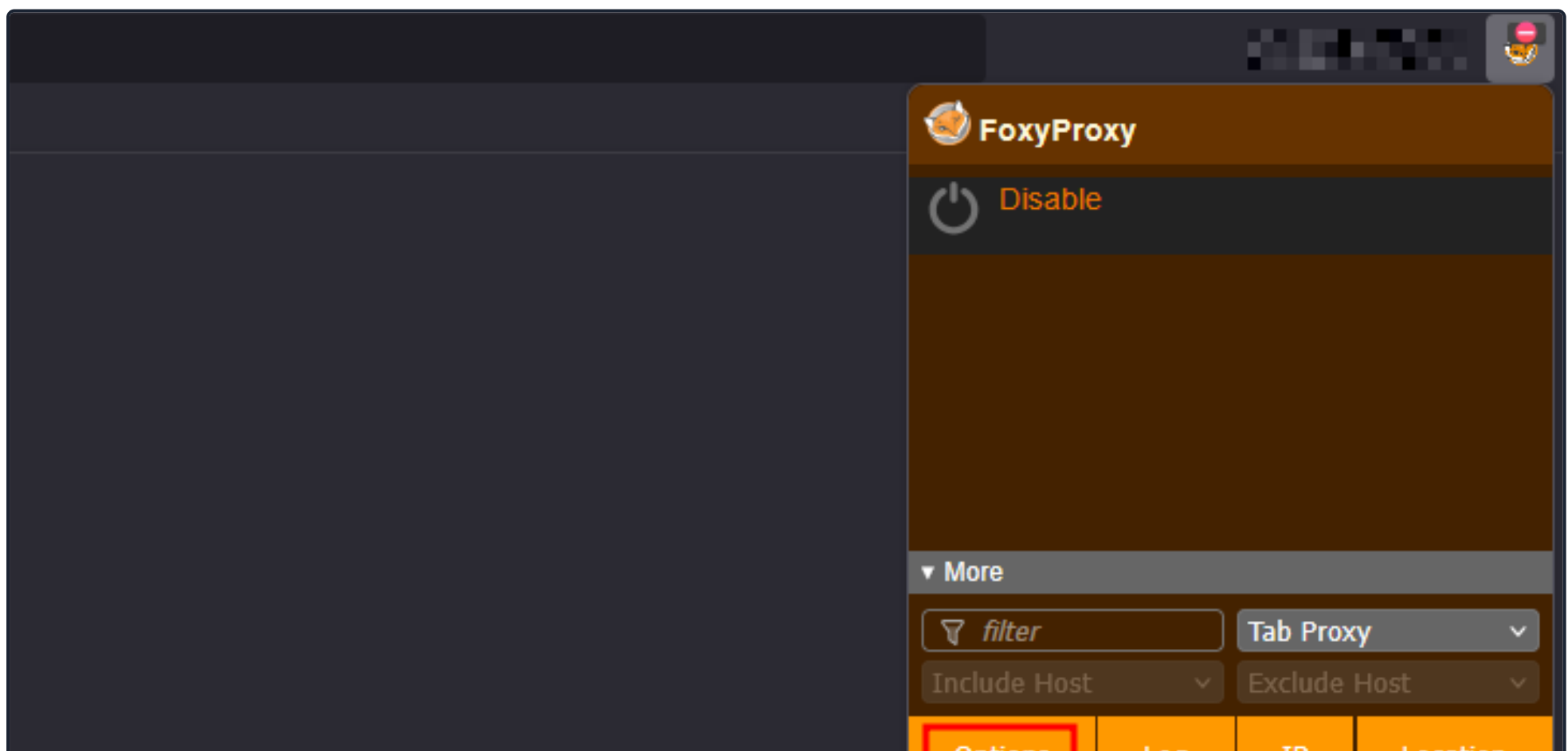


Inside the **Certificate Manager** dialog, open the **Authorities** tab, and click **Import**. Select the **cacert.der** file that we just downloaded, check both boxes, and click **Ok** to import the CA.



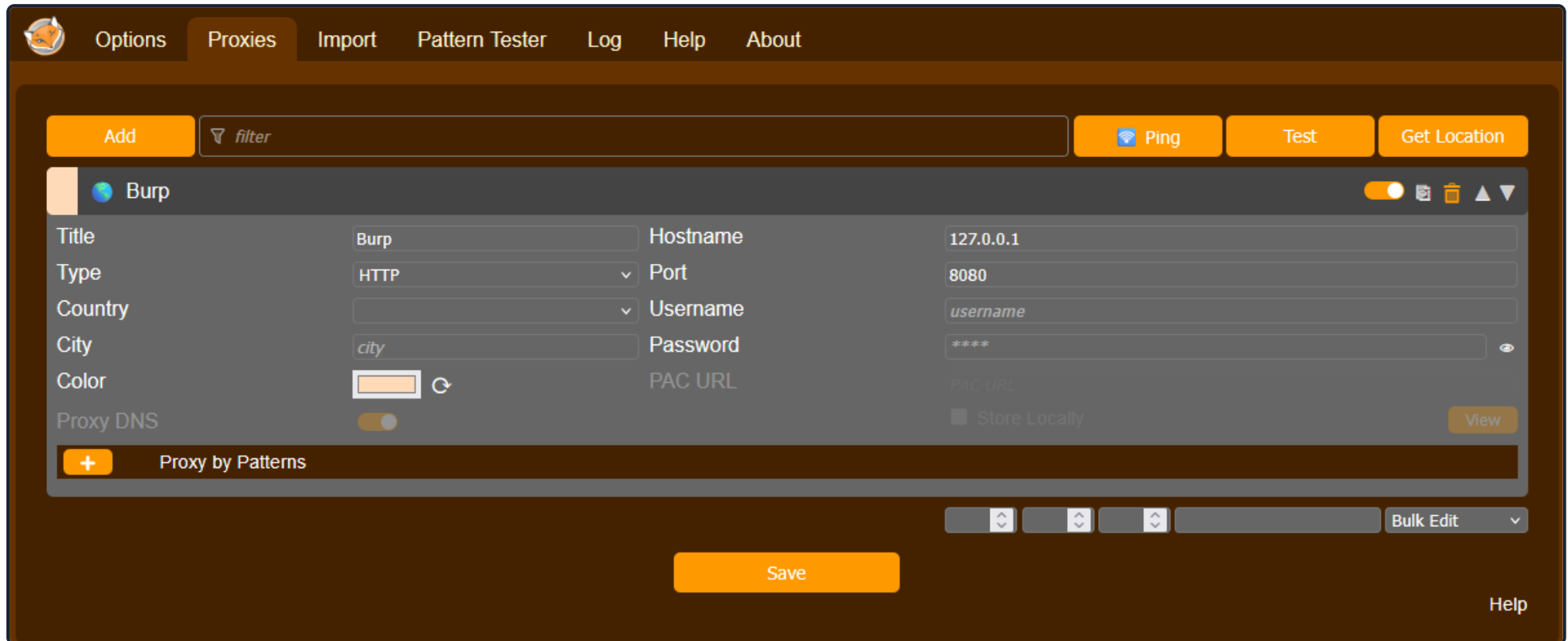
We can then utilize the Firefox extension **FoxyProxy** to easily and quickly change Firefox proxy settings. This extension is pre-installed in your PwnBox instance and can be installed on your own Firefox browser by visiting the [Firefox Extensions Page](#) and clicking **Add to Firefox** to install it.

Once we have the extension added, we can configure the web proxy on it by clicking on its icon in Firefox's top bar and then choosing **Options**:

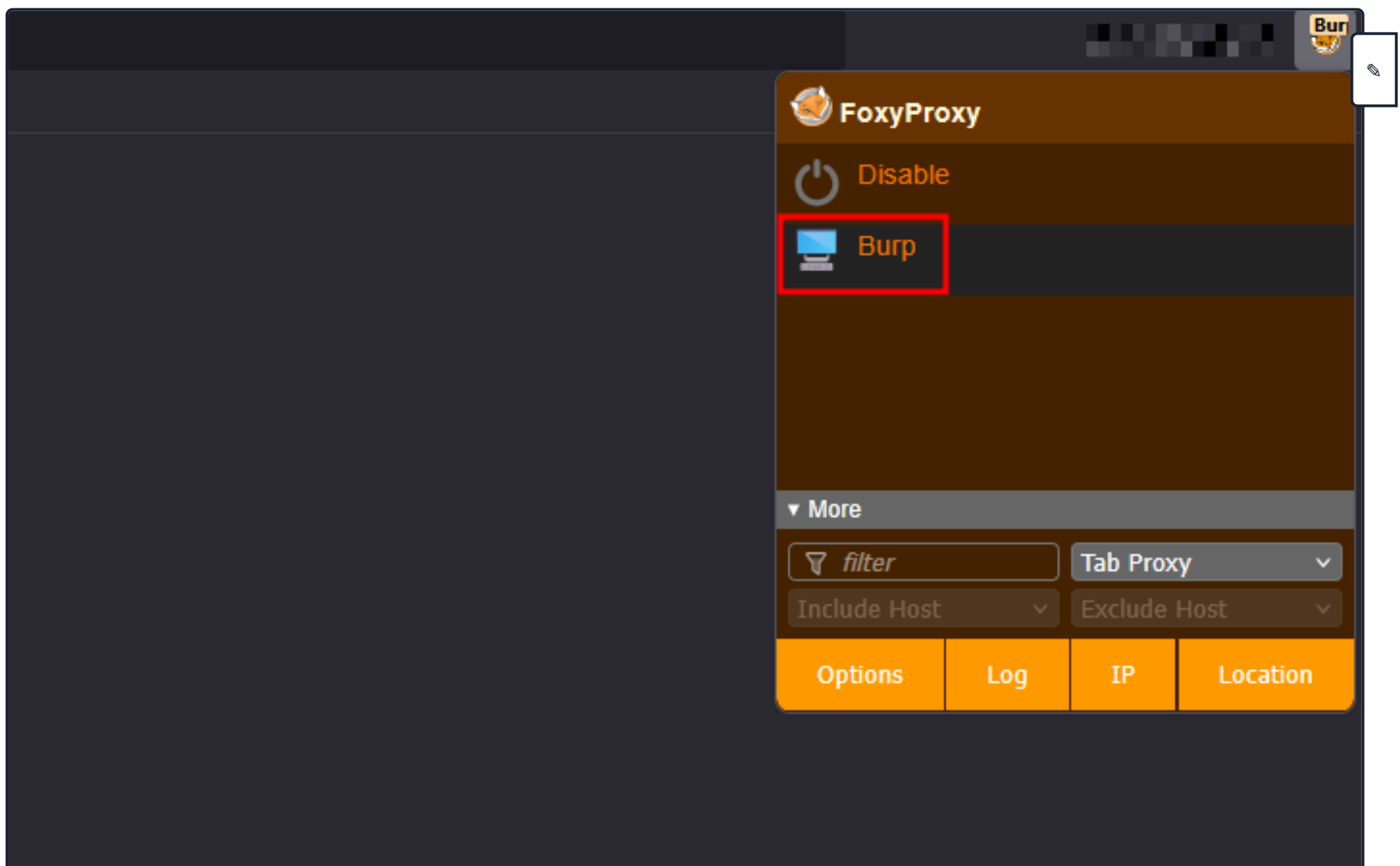




Once we're on the **Options** page, we can click on **Add** on the left pane, and then use **127.0.0.1** as the IP, and **8080** as the port, name it **Burp**, and click **Save**:

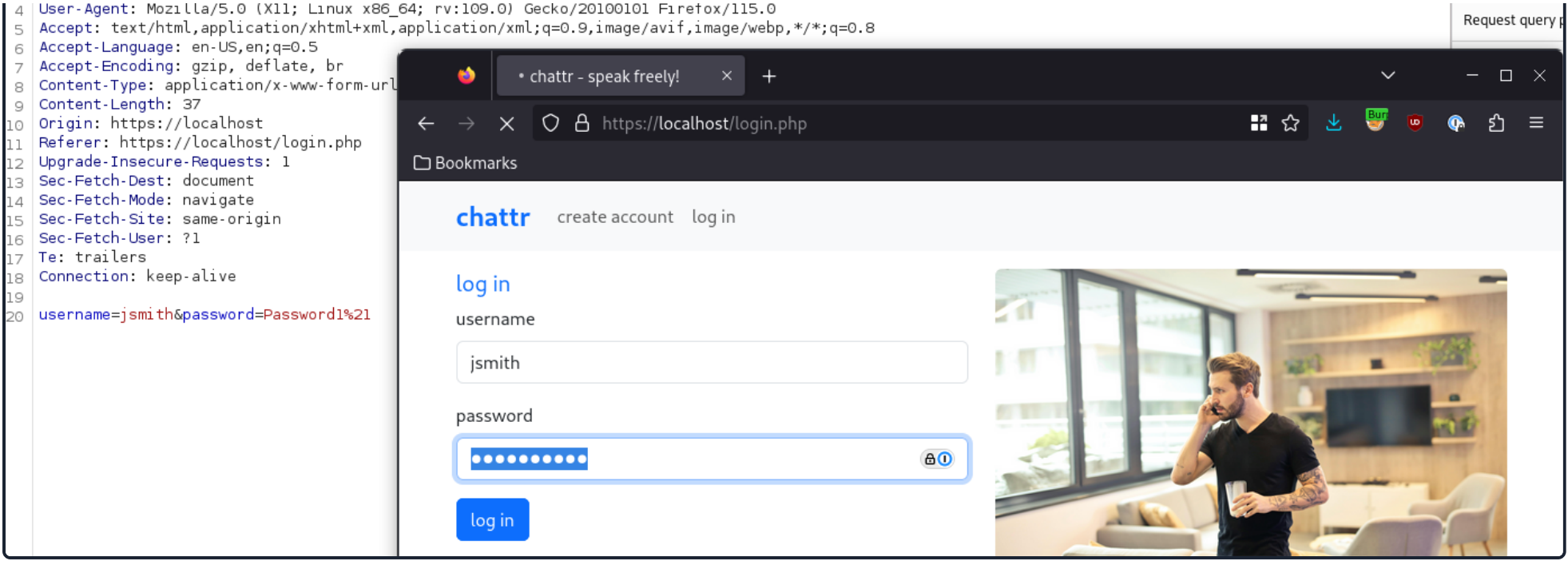


Finally, we can click on the **FoxyProxy** plugin icon and select **Burp**:



Once that's done, we should now be able to intercept HTTPS traffic in Burp Suite with no issues.





Note: If you are using **PwnBox** for the assessment, you do not need to install the Burp certificate separately, as it is pre-installed by default. Just make sure to select the **BURP** option on the FoxyProxy Firefox plugin.

Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

UK

210ms

Terminate Pwnbox to switch location

Start Instance

/ 1 spawns left

Waiting to start...

Questions

Cheat Sheet

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.61.88:37405

Life Left: 25 minute(s)

+ 1 What is the password hash for the user 'admin'?

\$argon2i\$v=19\$m=2048,t=4,p=3\$dk4wdDBraE0zZVllcEUudA\$CdU8zKxmToQybvtHfs1d5nHzjxw9DhkdcVToq6HTgvU

Submit

+ 1 What is the root path of the web application?

/var/www/chattr-prod

Submit

Hint

+ 1 Achieve remote code execution, and submit the contents of /flag_XXXXXX.txt below.

061b1aeb94dec6bf5d9c27032b3c1d8d

Submit

Previous

Finish



Cheat Sheet

Go to Questions

Table of Contents

Introduction	✓
Databases	
Intro to Databases	✓
Types of Databases	✓
MySQL	
Intro to MySQL	✓
SQL Statements	✓
Query Results	✓
SQL Operators	✓
SQL Injections	
Intro to SQL Injections	✓
Subverting Query Logic	✓
Using Comments	✓
Union Clause	✓

 Union Injection

✓

Exploitation

 Database Enumeration

✓

 Reading Files

✓

 Writing Files

✓

Mitigations

Mitigating SQL Injection

✓

Closing it Out

 [Skills Assessment - SQL Injection Fundamentals](#)

✓

My Workstation

OFFLINE

 Start Instance

∞ / 1 spawns left

